

PrepLab — Session 2 Notes

Threat Landscape & Risk Assessment

Step 1: What Kind of Organisation Is PrepLab Representing?

Nothing in the lab states industry/size explicitly, but the artefacts imply it clearly:

- Payroll data, supplier contracts, a "board pack" → small-to-mid organisation with normal corporate functions, not a bank or hospital.
- A single service account (svc-rep) with admin rights doing backup/reporting → thin IT team, not a large SOC.
- Backups going to S3, unencrypted, never restore-tested → cost-conscious, under-resourced operations.

This matters: sector, size and data determine the threat list (Session 2, Slide 4). A small org holding payroll + contract + customer data is **not** a state-actor target — it is a commodity-crime and insider-risk target.

Step 2: Crown Jewels (kept to 4, not 20)

#	Asset	Why it matters
1	Customer data ("full customer table" per backup notes)	Regulatory exposure (GDPR), reputational damage if breached
2	Credentials & secrets (APP_SECRET, DB_PASSWORD, service account passwords)	Single point of failure — compromise here unlocks everything else
3	Payroll & board records (RECORDS table)	Sensitive to employees/leadership; damaging if leaked
4	The svc-rep admin account itself	Over-privileged — compromising it IS compromising the whole app

Note: infrastructure (the database, the web server) is deliberately NOT listed as a crown jewel — that is where the jewels live, not the jewels themselves. Mapping where copies exist is Session 9 territory.

Step 3: Realistic Threat Actors

Actor	Realistic here?	Why
Organised crime	YES — primary	Ransomware/data theft for resale is the default threat for any org holding customer + payroll data. This environment fits the profile exactly: easy money via credential reuse, no MFA, exposed secrets.
Insider	YES — primary	Every account is admin (planted weakness #3). Insider risk isn't about malice — it's about blast radius when an ordinary mistake happens with excessive access (Slide 11).
Competitor / espionage	Possible, secondary	The board pack and supplier contract are the kind of IP a competitor might want, but nothing indicates this org is high-value/targeted enough to make this primary.
Activist	NO	No public-facing controversy or mission to attract activism.
State actor	NO	No strategic/critical-infrastructure indicators. Including this would repeat the "bank-grade defence, unlocked side door" mistake from Slide 7.

Step 4: Prioritised Risk List (likelihood × impact, evidence-based)

Pri.	Risk	Likelihood	Impact	Evidence
1	Credential/secret exposure → full account takeover	High	Critical	/debug leaks db_password, secret, usernames — unauthenticated, no skill required
2	Over-privileged service account (svc-rep = admin)	High	Critical	Confirmed by login; any leaked service credential = full admin, not just data access
3	IDOR on /record/<id> — full data exposure, no auth	High	High	Confirmed: payroll, contracts, board pack readable with zero session
4	Unauthenticated backup file share	High	High	backup-notes.txt readable by anyone, leaks a second credential pair
5	Session forgery via unsigned cookie	Medium	High	Confirmed mechanism; needs a session-checking endpoint to matter (login route ignores cookies)
6	Unencrypted, untested backups (needs prior access)	Medium	High	Stated directly in backup notes (encryption disabled, restore never tested)

Key observation: #1 and #2 share a root cause — secrets management and least privilege. Fixing that one thing knocks out #1, #2, and indirectly weakens #4 as well. This is the "prefer multi-purpose controls" principle from Slide 9 — the best return on a constrained budget.

Summary

PrepLab's realistic threat picture is commodity organised crime and careless/over-privileged insiders — not sophisticated or state-level adversaries. The single highest-leverage fix is centred on secrets handling and least privilege, since it addresses the two top-ranked risks at once. This threat picture and priority list carries forward into Session 3 (assessing what network controls can/cannot see) and Session 4 (testing whether segmentation actually holds).